📄 Fiche Synthèse : Comprendre le RGPD

1. Qu'est-ce que le RGPD ?

Le **RGPD** est le cadre juridique européen qui encadre le traitement des données personnelles. Entré en vigueur le **25 mai 2018**, il s'applique à toute organisation (publique ou privée) qui traite des données de citoyens européens.

2. Les 3 concepts clés

- **Donnée personnelle :** Toute information identifiante directement ou indirectement une personne (nom, IP, mail, empreinte, photo).
- **Traitement :** Toute opération sur ces données (collecte, stockage, modification, suppression).
- **Responsable de traitement :** L'entité qui définit l'objectif et les moyens du traitement.

3. Les 6 principes fondamentaux

Pour être conforme, tout traitement doit respecter ces règles :

1. **Légalité, loyauté, transparence :** On doit dire clairement ce qu'on fait des données.
2. **Limitation des finalités :** On ne collecte des données que pour un but précis (ex: une commande).
3. **Minimisation des données :** On ne collecte que le strict nécessaire (ne pas demander l'âge pour une newsletter).
4. **Exactitude :** Les données doivent être tenues à jour.
5. **Limitation de la conservation :** On ne garde pas les données indéfiniment.
6. **Intégrité et confidentialité :** Sécuriser les données contre le vol ou la perte.

4. Les droits des utilisateurs

Le RGPD redonne le pouvoir aux citoyens via plusieurs droits :

- **Droit d'accès :** Savoir quelles données sont détenues sur soi.
- **Droit de rectification :** Corriger des données fausses.
- **Droit à l'effacement (droit à l'oubli) :** Demander la suppression de ses données.
- **Droit à la portabilité :** Récupérer ses données pour les transférer ailleurs.
- **Droit d'opposition :** Refuser que ses données soient utilisées (ex: prospection commerciale).

5. Les obligations de l'entreprise (ou du technicien)

- **Tenir un registre des traitements :** Un document qui liste tout ce qu'on fait avec les données.
- **Sécurité informatique :** Chiffrement, mots de passe forts, sauvegardes, pare-feu.
- **Notification de violation :** En cas de piratage, l'entreprise a **72 heures** pour avertir la **CNIL**.
- **DPO (Data Protection Officer) :** Désigner un délégué à la protection des données si nécessaire.